

AdatTracker Pro

Complete Technical Architecture, Security Specifications & Disaster Recovery Reference

Repository: github.com/12thpassengineer/HabitTracker **Version:** v2.5 Enterprise Hardened **License:** MIT

Date: August 2026

1. Philosophy & Brand Identity

To eliminate third-party trademark liability, preserve complete code ownership, and build a high-performance personal habit operating system, the project was officially named **AdatTracker Pro**.

"You do not rise to the level of your goals. You fall to the level of your systems (adats)."

"Adat" (عادت / आदत) translates directly to *habit, ritual, or discipline* across South Asian and Middle Eastern cultures.

2. Feature Architecture

- **Monthly Habit Matrix:** 31-day widescreen grid with auto-scroll to today's date, streak counters (🔥), and completion rates (%).
- **Drag & Drop Priority Reordering:** Minimalist ☰ drag handles for real-time habit priority organization.
- **Proportional Consistency Scoring:** $\text{Daily Score} = \frac{\text{Completed Habits}}{\text{Total Active Habits}}$ (e.g. 4/5 habits = +0.80 pts).
- **OLED Sticky Notes Pad:** 6 color palettes (Yellow, Green, Purple, Cyan, Pink, Slate) with Pin (📌), Copy (📄), and search.
- **Passwordless Email OTP:** 6-digit cryptographic verification with 10-minute expiry and attempt lockout.
- **2-Second Contextual Hover Guides:** Automatic dwell helper modals on all statistics and controls.
- **Offline Local Mode:** Automatic fallback to browser localStorage if server connection is lost.

3. Security Architecture & Threat Model

 Security Guarantees

Zero tokens in localStorage • HttpOnly SameSite=Lax cookie sessions • CSRF double-submit protection • Database-backed rate limiting • Non-root execution (UID 1001) • SQLite WAL mode • Strict user isolation.

Security Layer	Mechanism	Implementation Detail
Authentication	Passwordless Email OTP	HMAC-SHA256 hashed with server SECRET_KEY salt, single-use, 10-min expiry, multi-code race protection.
Session Management	HttpOnly Cookies	256-bit URL-safe session token, 30-day expiry, SameSite=Lax, Secure flag in production.
CSRF Defense	Double-Submit Header	All state-mutating POST requests validate X-CSRF-Token against the session database.
User Isolation	Server-Enforced User ID	Server derives identity solely from session cookie. Client-supplied user_id query params are strictly ignored.
Rate Limiting	Database-Backed Limiter	IP and Email rate limiting (Cloudflare CF-Connecting-IP aware), cooldown lockout after 5 incorrect guesses.
Payload Security	Size Capping & CSP	Requests > 512 KB receive 413 Payload Too Large. Strict CSP headers block unauthorized scripts.

4. Multi-Backend Email Dispatcher

- Resend API Backend:** Modern transactional delivery supporting verified custom domains (e.g. noreply@darsan.co.in).
- Standard SMTP Backend:** Universal SMTP integration for Gmail (App Passwords), Amazon SES, Mailgun, Brevo (STARTTLS / SSL).
- Console Simulator:** Zero-dependency development mode printing prominent ASCII verification boxes into container logs.

5. Complete Database Schema (SQLite WAL)

```
-- High Concurrency WAL Configuration
PRAGMA journal_mode = WAL;
PRAGMA foreign_keys = ON;
```

```
PRAGMA busy_timeout = 5000;
PRAGMA synchronous = NORMAL;

-- 1. Users Table
CREATE TABLE IF NOT EXISTS users (
    id TEXT PRIMARY KEY,
    username TEXT UNIQUE NOT NULL COLLATE NOCASE,
    email TEXT UNIQUE NOT NULL COLLATE NOCASE,
    role TEXT NOT NULL DEFAULT 'user',
    is_verified INTEGER NOT NULL DEFAULT 1,
    created_at TEXT NOT NULL,
    last_login TEXT NOT NULL
);

-- 2. Email OTPs Table
CREATE TABLE IF NOT EXISTS email_otps (
    id INTEGER PRIMARY KEY AUTOINCREMENT,
    email TEXT NOT NULL COLLATE NOCASE,
    otp_hash TEXT NOT NULL,
    purpose TEXT NOT NULL,
    attempts INTEGER NOT NULL DEFAULT 0,
    expires_at TEXT NOT NULL,
    used INTEGER NOT NULL DEFAULT 0,
    ip_address TEXT,
    created_at TEXT NOT NULL
);

-- 3. Server-Side Sessions Table
CREATE TABLE IF NOT EXISTS sessions (
    id TEXT PRIMARY KEY,
    user_id TEXT NOT NULL,
    csrf_token TEXT NOT NULL,
    expires_at TEXT NOT NULL,
    ip_address TEXT,
    user_agent TEXT,
    created_at TEXT NOT NULL,
    FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
);

-- 4. Rate Limits Table
CREATE TABLE IF NOT EXISTS rate_limits (
    key TEXT PRIMARY KEY,
    attempts INTEGER NOT NULL DEFAULT 0,
    window_start TEXT NOT NULL,
    blocked_until TEXT
);

-- 5. User Data Table (Strictly isolated by user_id)
CREATE TABLE IF NOT EXISTS user_data (
    user_id TEXT PRIMARY KEY,
    data_json TEXT NOT NULL,
    updated_at TEXT NOT NULL,
```

```

version INTEGER DEFAULT 1,
FOREIGN KEY (user_id) REFERENCES users(id) ON DELETE CASCADE
);

```

6. Portainer Stack Specification

```

version: '3.8'

services:
  adatracker:
    image: python:3.11-slim
    container_name: adatracker-pro
    restart: unless-stopped
    ports:
      - "8000:8000"
    environment:
      - APP_ENV=local
      - EMAIL_BACKEND=resend
      - RESEND_API_KEY=re_Sic813cq_HoHB7NKTnggPy7c1SQRqCT37
      - FROM_EMAIL=noreply@darsan.co.in
      - FROM_NAME=AdatTracker
      - SECRET_KEY=adatracker_pi_secret_key_32bytes_min_length_secure
      - PORT=8000
      - HOST=0.0.0.0
      - DATA_DIR=/app/data
    volumes:
      - adatracker_data:/app/data
    command: >
      sh -c "apt-get update -qq && apt-get install -y -qq git curl &&
        mkdir -p /app/data && cd /app &&
        rm -rf repo &&
        git clone https://github.com/12thpassengineer/HabitTracker.git repo &&
        cd repo &&
        pip install --no-cache-dir -r requirements.txt --quiet &&
        python server.py"

volumes:
  adatracker_data:

```

7. Cloudflare Tunnel Deployment Blueprint

```

# /etc/cloudflared/config.yml
tunnel: <TUNNEL_UUID>
credentials-file: /etc/cloudflared/<TUNNEL_UUID>.json

```

```
ingress:
  - hostname: habits.darsan.co.in
    service: http://localhost:8000
  - service: http_status:404
```

8. Automated WAL Backup Script

```
#!/usr/bin/env bash
set -e
APP_DIR="/opt/adattracker"
DB_PATH="$APP_DIR/data/adattracker.db"
BACKUP_DIR="/opt/adattracker/backups"
TIMESTAMP=$(date +%Y%m%d_%H%M%S")
BACKUP_FILE="$BACKUP_DIR/adattracker_backup_${TIMESTAMP}.db"

mkdir -p "$BACKUP_DIR"
sqlite3 "$DB_PATH" ".backup '$BACKUP_FILE'"
chmod 600 "$BACKUP_FILE"

# Rotate backups older than 14 days
find "$BACKUP_DIR" -name "adattracker_backup_*.db" -type f -mtime +14 -delete
```

9. 16-Point Automated Security Test Suite

```
python tests/test_security.py
```

Verifies user data isolation, unauthenticated request rejection, single-use OTP enforcement, replay protection, rate limits, SQL injection safety, XSS protection, CSRF token validation, and 512 KB payload size caps.